

Combating Ransomware



October 2024

Introduction

This guide provides comprehensive information on ransomware mitigation strategies, incorporating activities from the National Institute of Standards & Technology (NIST) Cybersecurity Framework (CSF) and NIST 800-53. It is designed to help organizations enhance their cybersecurity posture and effectively combat ransomware threats.

The information presented here is based on recommendations from the Multi-State Information Sharing & Analysis Center® (MS-ISAC®) Metrics Working Group, which advises the federally funded Nationwide Cybersecurity Review (NCSR) assessment program.

Understanding Ransomware

What is Ransomware?

Ransomware is a type of malicious software (malware) that restricts access to a computer system or files, typically through encryption. The attacker then demands a ransom payment to restore access. This can result in significant productivity loss, financial damage, and reputational harm to an organization.

How Does Ransomware Spread?

Common vectors for ransomware include:

Email (Phishing)

- Users clicking on malicious links or attachments in spam emails
- Divulging personal information through deceptive emails

Compromised Passwords/Credentials

- Weak passwords
- Compromised user authentication
- Credential abuse

Vulnerabilities

- Unpatched software or systems
- “Drive-by downloading” or malicious apps from app stores

Remote Desktop Protocol (RDP)

- Unsecured remote access points

Preventing Ransomware Attacks



Email Security

Organizational Recommendations

- Implement robust spam filters
- Train employees to recognize and report phishing attempts
- Use email authentication protocols

Related NIST CSF Activities

- ID.RA-3: Identify and document internal and external threats
- DE.CM-4: Detect malicious code

Related NIST 800-53 Controls

- SI-3: Employ and update malicious code protection mechanisms
- SI-8: Implement and manage spam protection mechanisms



Access Control

Organizational Recommendations

- Enforce strong password policies
- Implement multi-factor authentication
- Manage user access rights following the principle of least privilege
- Secure remote access, including RDP

Related NIST CSF Activities

- PR.AC-1: Manage identities and credentials
- PR.AC-4: Manage access permissions
- PR.AT-1: Inform and train all users
- PR.AT-2: Ensure privileged users understand their roles and responsibilities

Related NIST 800-53 Controls

- AC-7: Enforce limits on consecutive invalid logon attempts
- IA-3: Manage elevated user authentications
- IA-10: Implement strong password requirements



Vulnerability Management

Organizational Recommendations

- Regularly scan for and patch vulnerabilities
- Keep all software and systems up to date
- Develop and maintain a vulnerability management plan

Related NIST CSF Activities

- ID.RA-1: Identify and document asset vulnerabilities
- ID.RA-5: Use threats, vulnerabilities, likelihoods, and impacts to determine risk
- DE.CM-8: Perform vulnerability scans
- PR.IP-12: Develop and implement a vulnerability management plan
- RS.MI-3: Mitigate newly identified vulnerabilities

Related NIST 800-53 Controls

- RA-3: Conduct risk assessments
- RA-5: Perform vulnerability scanning and monitoring



Network Security

Organizational Recommendations

- Use firewalls and network segmentation
- Monitor for unauthorized access or unusual activity
- Limit IP access where possible

Related NIST CSF Activities

- PR.AC-3: Manage remote access
- PR.MA-2: Manage remote maintenance
- DE.CM-7: Monitor for unauthorized personnel, connections, devices, and software

Related NIST 800-53 Controls

- AC-17: Implement secure remote access controls
- SI-4: Monitor information



Endpoint Protection

Organizational Recommendations

- Install and maintain antivirus and anti-malware software
- Deploy Endpoint Detection and Response (EDR) solutions

Related NIST CSF Activities

- DE.CM-4: Detect malicious code
- PR.DS-6: Implement integrity checking mechanisms

Related NIST 800-53 Controls

- SI-3: Employ malicious code protection mechanisms
- SI-7: Implement software, firmware, and information integrity controls



Employee Training

Organizational Recommendations

- Conduct regular cybersecurity awareness training
- Perform simulated phishing campaigns to test employee readiness

Related NIST CSF Activities

- PR.AT-1: Inform and train all users
- PR.AT-2: Ensure privileged users understand their roles and responsibilities

Related NIST 800-53 Controls

- AT-2: Conduct security awareness training, including recognizing potential insider threats

Preparing for a Potential Ransomware Attack



Backup and Recovery

Organizational Recommendations

- Maintain regular, secure backups of all critical data
- Store backups offline or in a separate, secure location
- Regularly test the restoration process

Related NIST CSF Activities

- PR.IP-4: Backup information
- PR.IP-9: Response plans and recovery plans are in place and managed

Related NIST 800-53 Controls

- CP-9: Conduct system backups
- CP-10: Provide for information system recovery and reconstitution



Incident Response Planning

Organizational Recommendations

- Develop a comprehensive incident response plan
- Identify key personnel and their roles in responding to an attack
- Establish communication protocols for internal and external stakeholders

Related NIST CSF Activities

- RS.RP-1: Execute response plan during or after an incident
- RS.CO-1: Ensure personnel know their roles and order of operations when a response is needed

Related NIST 800-53 Controls

- IR-4: Implement incident handling capabilities
- IR-8: Establish an incident response plan

Responding to a Ransomware Attack

If you suspect a ransomware attack:

-  1 Isolate affected systems to prevent spread.
-  2 Report the incident to appropriate authorities.
-  3 Activate your incident response plan.
-  4 Restore systems and data from secure backups.
-  5 Conduct a post-incident review to improve future preparedness.

Note: It is generally not recommended to pay the ransom, as this does not guarantee data recovery and may encourage further attacks.

The Nationwide Cybersecurity Review (NCSR) and Ransomware Mitigation

The NCSR is a valuable tool for organizations to self-assess their cybersecurity maturity. By taking the NCSR, organizations can more effectively:

- Identify gaps in their cybersecurity practices
- Benchmark their security posture against peers
- Prioritize areas for improvement

The NCSR is mapped to the NIST CSF, which means that as organizations implement the ransomware mitigation strategies outlined in this guide, they should see an improvement in their NCSR scores. This correlation helps organizations:

- Track progress in their ransomware preparedness
- Justify investments in cybersecurity measures
- Demonstrate improved security posture to stakeholders

Essential Cyber Hygiene Best Practices

In addition to the specific measures outlined above, organizations should implement these essential cyber hygiene best practices:

-
- ✓ **Put RDP behind a firewall**
 - ✓ **Require complex passwords**
 - ✓ **Employ multi-factor authentication**
 - ✓ **Limit IP access**
 - ✓ **Maintain comprehensive logs**
 - ✓ **Implement a consistent patching process for all assets**
 - ✓ **Consistently back up data and test restoration processes**
 - ✓ **Install Endpoint Detection & Response (EDR) and virus protection**
 - ✓ **Conduct annual user cybersecurity training and phishing campaigns**
 - ✓ **Perform monthly vulnerability scans**

Additional Resources

For more detailed guidance, refer to the [Cybersecurity and Infrastructure Security Agency \(CISA\) “Stop Ransomware” Guide](#). This guide, created by the U.S. Joint Ransomware Task Force:

- ⊕ Promotes collaboration between government agencies and private sector partners
- ⊕ Offers best practices for attack preparation, prevention, and response
- ⊕ Emphasizes the significance of securing critical data and systems
- ⊕ Highlights the importance of minimizing the risks of automated backups
- ⊕ Stresses the necessity of a robust cyber incident response plan
- ⊕ Advises against paying the ransom
- ⊕ Provides a checklist on how to respond to an attack
- ⊕ Offers additional resources to organizations on how to combat ransomware attacks

Action Required

Ransomware remains one of the most significant cybersecurity threats facing organizations today. By implementing the strategies outlined in this guide, organizations can significantly improve their ability to prevent, detect, and respond to ransomware attacks. Remember:

Prevention is key	Focus on strong access controls, regular patching, and employee training.
Preparation is crucial	Maintain secure backups and develop comprehensive incident response plans.
Continuous improvement is necessary	Regularly assess your cybersecurity posture using tools like the NCSR and update your practices accordingly.

By taking a proactive approach to ransomware mitigation, organizations can enhance their overall cybersecurity posture, protect their valuable assets, and maintain the trust of their stakeholders.

The Center for Internet Security, Inc. (CIS®) makes the connected world a safer place for people, businesses, and governments through our core competencies of collaboration and innovation.

We are a community-driven nonprofit, responsible for the CIS Controls® and CIS Benchmarks™, globally recognized best practices for securing IT systems and data. We lead a global community of IT professionals to continuously evolve these standards and provide products and services to proactively safeguard against emerging threats. Our CIS Hardened Images® provide secure, on-demand, scalable computing environments in the cloud.

CIS is home to the Multi-State Information Sharing and Analysis Center® (MS-ISAC®), the trusted resource for cyber threat prevention, protection, response, and recovery for U.S. State, Local, Tribal, and Territorial government entities.



 www.cisecurity.org

 info@cisecurity.org

 518-266-3460

 Center for Internet Security

 CenterforIntSec

 @CISecurity

 TheCISecurity

 cisecurity